

NFC Card and Tag Security Enhancement Framework Using Hybrid Detection

Multi-Session Protocol and Timing Fingerprinting for NFC Clone
Detection

J26-CS-316

Project Proposal Report

Anulasha K.A. - IT23139480

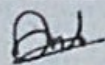
B.Sc (Hons) Degree in Information Technology Specialized in
Cyber Security

Department of Information Technology
Sri Lanka Institute of Information Technology Sri Lanka

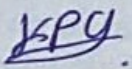
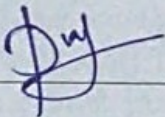
September 2026

DECLARATION

I declare that this is my own work, and this proposal does not knowingly incorporate any material previously submitted for a degree or diploma at any other university or higher education institution, nor does it contain any material that has been previously published or written by another person apart from where proper acknowledgment is given in the text.

Name	Student ID	Signature
Anulasha K.A.	IT23139480	

The above candidate is conducting research for their undergraduate Dissertation under my supervision.

Name	Date	Signature
K. P. Yapa	15/09/2026	
Ms. Dinita Panditase	15/09/2026	

ABSTRACT

Contactless credentials in legacy deployments are often authorized on transmitted identity data alone. If that data can be reproduced on writable-identifier media or presented by an emulator, the reader has no basis to distinguish the enrolled physical source from a copy. Published work shows that RFID and NFC devices carry measurable hardware-dependent characteristics, but the strongest results depend on oscilloscopes, software-defined radios, purpose-built readers, or wideband backscatter collectors. None of these is present in an access-control installation. The closest NFC-specific study identifies 50 tags from software-defined radio samples with high accuracy. Yet, it divides repeated samples of those same 50 tags between training and evaluation, so it demonstrates identification of enrolled tags rather than generalization to a card the model has never seen. Open RFID benchmark data records event-level attack traces without the ISO/IEC 14443 protocol-response and reader-side timing fields that provenance fingerprinting needs. Component C2 investigates whether multi-session protocol-response evidence collected with a Proxmark3 research reader can separate original-like, clone-like, and emulator-like sources when both the test card and the test session were absent from training. Laboratory cards from the MIFARE Classic 1K and NTAG21x families, authorized clone-like copies written to project-owned media, and an authorized emulator are measured repeatedly across independent sessions on separate days. Session fingerprints combine non-identity protocol behavior, timing distributions, authentication outcomes, and stability evidence. Random Forest, Support Vector Machine and k-Nearest Neighbor models are compared under splits grouped by physical source, with a calibrated rejection layer that returns UNKNOWN instead of forcing a class. Reporting covers genuine-versus-clone discrimination, false acceptance, held-out source generalization, cross-session stability, and unseen-source rejection. I report emulator results separately so one device cannot inflate the headline figure.

Keywords: NFC provenance; protocol-response fingerprinting; clone detection; open-set recognition; leakage-safe evaluation

ACKNOWLEDGEMENT

I would like to thank my supervisor and co-supervisor for the guidance and critical feedback that shaped both the direction of this research and the standard of evidence it sets for itself. The questions raised during our discussions greatly helped sharpen the scope of this component.

I am grateful to the Faculty of Computing, Sri Lanka Institute of Information Technology, for providing the academic environment and institutional support for this work, and to the Joint Research Committee for the hardware approval process that enabled controlled laboratory experimentation.

I would also like to thank my fellow members of group J26-CS-316 for collaboratively designing the shared framework and coordinating the common hardware and integration interfaces on which this component depends.

Finally, I thank my family for their patience and encouragement throughout this project.

TABLE OF CONTENTS

DECLARATION.....	2
ABSTRACT.....	3
ACKNOWLEDGEMENT	4
TABLE OF CONTENTS	5
LIST OF FIGURES	7
LIST OF TABLES	8
LIST OF ABBREVIATIONS	9
1. INTRODUCTION	11
1.1 Background and Context.....	11
1.2 Literature Review.....	14
1.3 Research Gap	18
2. OBJECTIVE	20
2.1 Main Objective.....	20
2.2 Specific Objectives	20
3. METHODOLOGY	21
3.1 Research Methodology and Design	21
3.2 Data, Participants and Experimental Inputs.....	21
3.3 Baselines and Ablations	29
3.4 Evaluation Metrics	30
3.5 Validation Strategy	31
4. HIGH-LEVEL SYSTEM ARCHITECTURE.....	33
4.1 Overview of the Proposed Solution	33
4.2 C2 Internal Architecture.....	34
4.3 Overall Integration	34
4.4 Individual Responsibility Boundary	35
5. USER REQUIREMENTS	36
5.1 Requirements Elicitation and Evidence Status	36
5.2 Functional Requirements	36
5.3 Non-Functional Requirements	37
6. COMMERCIALIZATION PLAN	38
6.1 Target Market and Customer Persona	38

6.2 Value Proposition	38
6.3 Revenue Model	39
6.4 Cost and Pricing Strategy.....	39
6.5 Competitive Advantage and Commercial Risks	39
6.6 Intellectual Property Considerations.....	40
7. BUDGET AND JUSTIFICATION	41
8. WORK BREAKDOWN STRUCTURE (WBS).....	42
8.1 Task Breakdown and Workload	42
9. GANTT CHART	44
10. REFERENCES	45
11. APPENDICES.....	47
Appendix A. Source Registry and Physical Corpus.....	47
Appendix B. Standard Acquisition and Session Checklist	47
Appendix C. Dataset Schema and Split Rules	48
Appendix D. Ethics, JRC and Evidence Status.....	48
Appendix E. UI Sketch - C2 Provenance Dashboard	49
Appendix 2. Mandatory Proposal Evidence and Decision Log	50
Appendix 3. AI Use Disclosure	51

LIST OF FIGURES

Figure 1:Why static-identity verification can fail against a duplicate credential.	11
Figure 2:From established evidence to the C2 research gap.....	19
Figure 3:Acquisition tiers and the evidence available at each tier.....	23
Figure 4:Controlled multi-session acquisition protocol designed to minimise session- and positioning-related confounding.	24
Figure 5:. Session fingerprint construction from repeated observations.	28
Figure 6:. Evaluation ladder - baselines, ablations and grouped splits.	29
Figure 7:High-level architecture of the four-component framework.....	33
Figure 8:C2 internal workflow, training path and verification path.	34
Figure 9:Gantt chart for the 15-week research period.	44
Figure 10:Simplified UI Sketch of the C2 Provenance Dashboard.	49

LIST OF TABLES

Table 1: Comparison of existing approaches and the evidence behind them.	18
Table 2:Original C2 concept versus the revised C2 research design.	19
Table 3:Physical corpus, class design and the role of each family.	22
Table 4:Target sample sizes.	25
Table 5:Canonical dataset schema.	27
Table 6:Evaluation metrics and reporting rules.	30
Table 7:Validation experiments E1 to E7.....	31
Table 8:Individual responsibility boundary.....	35
Table 9:Functional requirements.....	37
Table 10:Non-functional requirements.	38
Table 11:Budget and justification.	41
Table 12:Work breakdown structure.	43

LIST OF ABBREVIATIONS

3DES - Triple Data Encryption Standard

AES - Advanced Encryption Standard

APDU - Application Protocol Data Unit

ATQA - Answer To Request, Type A

ATS - Answer To Select

C1 - Component 1 - NFC Security Profile Scoring

C2 - Component 2 - Multi-Session Protocol-Response Provenance Fingerprinting

C3 - Component 3 - NFC Tag Data Integrity Verification

C4 - Component 4 - Hybrid Behavioral Anomaly Detection

CSV - Comma-Separated Values

CV - Coefficient of Variation

FAR - False Acceptance Rate

FDT - Frame Delay Time

FRR - False Rejection Rate

HF - High Frequency

IQR - Interquartile Range

ISO/IEC - International Organization for Standardization / International Electrotechnical Commission

JRC - Joint Research Committee

JSON - JavaScript Object Notation

KNN - k-Nearest Neighbor

ML - Machine Learning

N/A - Not Applicable

NFC - Near-Field Communication

NFR - Non-Functional Requirement

NTAG - NFC Tag product family

PC/SC - Personal Computer / Smart Card
RF - Random Forest
RFID - Radio-Frequency Identification
SAK - Select Acknowledge
SDG - Sustainable Development Goal
SDR - Software-Defined Radio
SLIIT - Sri Lanka Institute of Information Technology
SO - Specific Objective
SVM - Support Vector Machine
TAF - Topic Assessment Form
UHF - Ultra-High Frequency
UID - Unique Identifier
USB - Universal Serial Bus
WBS - Work Breakdown Structure

1. INTRODUCTION

1.1 Background and Context

1.1.1 Real-world problem

Contactless cards and tags are widely used because they are fast, low-cost, and easy to integrate. However, their security depends on what the reader verifies. In weak or legacy systems, authentication may rely mainly on a static UID or reproducible card data. MIFARE Classic is a well-known example, as weaknesses in CRYPTO-1 showed that such credentials can become unsuitable for high-assurance authentication [6]. This proposal does not assume that all NFC credentials are clonable; modern cards using strong challenge-response authentication are outside the scope.

The C2 problem begins when a clone or emulator can present a plausible identity. In this case, identity data alone cannot prove physical origin. C2 therefore investigates whether the source can be identified from physical and protocol-response behavior across controlled interactions. Prior fingerprinting research suggests that manufacturing differences can produce measurable, device-specific characteristics [1]–[5].

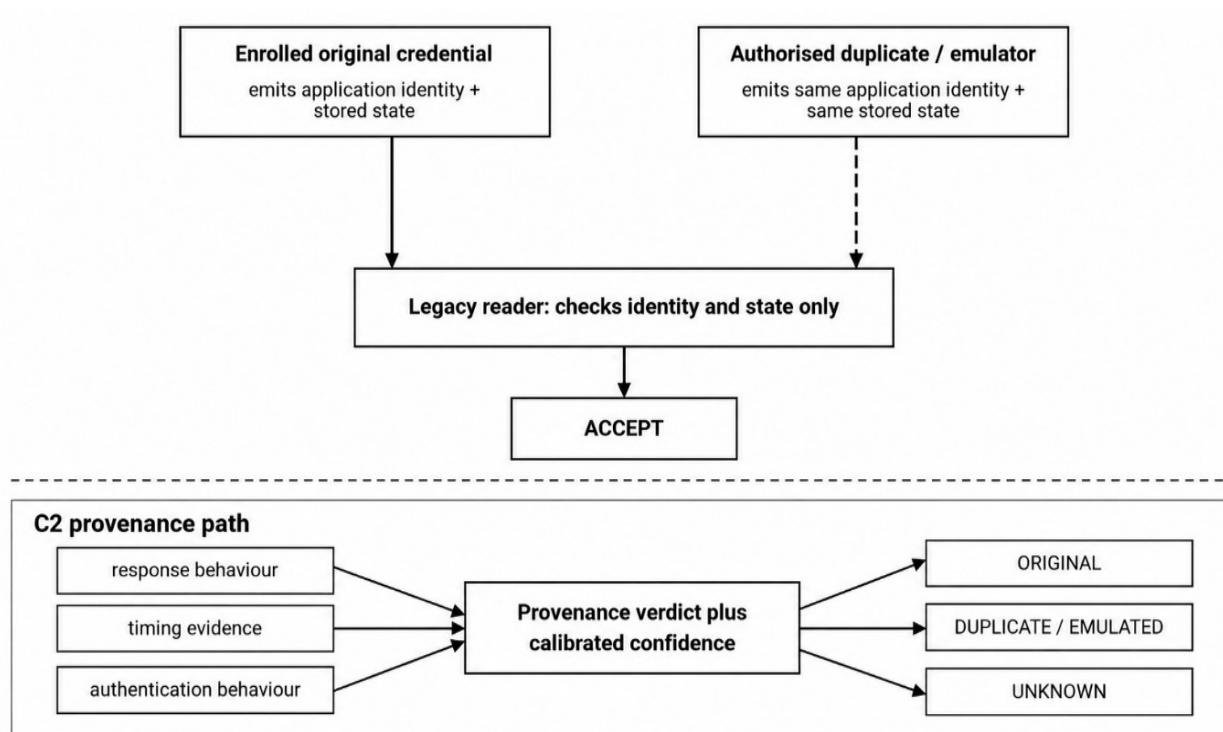


Figure 1: Why static-identity verification can fail against a duplicate credential.

1.1.2 Who is affected and why it matters

- Organizations running legacy card-based access control, where a duplicated credential creates an authentication ambiguity even though no physical card has gone missing.
- Credential holders, because the access log records an identity and not which physical source presented it.
- Incident investigators, who currently have no provenance evidence to separate "the holder entered" from "a copy of the holder card entered".
- System integrators, for whom full migration to stronger credentials means replacing cards, readers and enrolment processes, and who have no interim assessment layer to offer in the meantime.

1.1.3 Evidence for the problem

Several independent lines of published Evidence support the problem statement. Garcia et al. demonstrated the security failure of MIFARE Classic and the practical significance of weaknesses in legacy contactless credentials [6]. Lehtonen et al. treated cloning as a security problem in its own right and proposed a back-end mechanism that detects duplicate identities by synchronizing mutable tag state, establishing clone detection as an alternative to making the tag itself uncloneable [7]. Fingerprinting studies then show that the devices carry measurable hardware-dependent characteristics: Romero et al. measured ISO 14443 cards with laboratory electromagnetic instrumentation [2], Zanetti et al. identified UHF tags from timing and spectral features using a purpose-built reader [3], Li et al. used wideband backscatter profiles [4], and Lee et al. separated 50 NFC tags using an NFC reader combined with a software-defined radio and deep learning [5].

No verified local incident dataset or stakeholder study was available when this proposal was written, so no claim is made about the prevalence of credential cloning in Sri Lanka. Inventing a statistic would be worse than having none. Local deployment evidence is therefore treated as a scheduled requirements-validation activity rather than as a fact.

1.1.4 Existing solutions and their limitations

Four approaches exist, and each leaves a different part of the problem unsolved.

Cryptographic migration strengthens authentication at the credential itself. It is the correct engineering answer where applicable, but it requires a compatible credential and reader population, and it does nothing for the installed base that motivates this component.

Back-end duplicate detection, such as the synchronized-secret method of Lehtonen et al. [7], detects inconsistent state once both the genuine and the duplicate credential have been scanned. It is a useful control. It does not assess the source presenting itself right now, and it depends on writable state and on subsequent observations.

Physical-layer fingerprinting provides the strongest source evidence, and the published results are good. The constraint is instrumentation. The methods in [2] to [5] rely on an oscilloscope, a software-defined radio, a purpose-built UHF reader or a wideband collector, and no access-control reader contains any of these.

Commodity and research-reader evidence is the remaining option, and it is the least explored. RFID-ExSim shows that low-cost MFRC522 readers can collect large event-level traces under cloning and replay conditions, but its fields describe events, scenarios, distance, and orientation rather than ISO/IEC 14443 protocol-response behavior [10]. The protocol-response and reader-side timing route that this component takes is therefore not yet characterized in the literature reviewed here.

1.1.5 Proposed C2 solution and its novelty

C2 examines a practical intermediate layer. Multi-session protocol-response provenance fingerprinting is collected using a Proxmark3 research reader through standardized, non-destructive interactions with laboratory cards owned by the project. The contribution does not assert the novelty of fingerprinting itself. Instead, it integrates a deployable evidence source with an evaluation design that assesses whether the evidence remains valid beyond the specific physical samples and sessions used for training. This contribution is supported by six key design choices.

- Multi-session data acquisition conducted across separate days, with the experimental setup reconstructed between sessions, rather than relying on a single collection batch.
- Grouped evaluation in which an entire physical source is excluded from training whenever it is used for testing, preventing the model from succeeding through memorization.
- Family-matched analysis to ensure that chip family or test-media type does not serve as an unintended proxy for the provenance label.
- Primary genuine-versus-clone results are reported separately from the emulator class, ensuring that a single emulator device does not artificially increase the headline metric.
- An open-set rejection layer returns UNKNOWN for unfamiliar evidence, rather than forcing assignment to one of the recognized classes.
- Protocol-only, timing-only, and combined ablation studies quantify which evidence group contributes most significantly to the decision process.

1.1.6 SDG alignment

- SDG 9, Industry, Innovation and Infrastructure: enhances the security assessment of contactless infrastructure and facilitates evidence-based migration decisions.
- SDG 11, Sustainable Cities and Communities: contactless credentials provide foundational support for building, campus, and transport access.
- SDG 16, Peace, Justice and Strong Institutions: strengthens identity assurance and enables more robust investigation of credential-related incidents.

1.1.7 Research cluster and key pillar alignment

The primary research area is Cyber Security and Digital Forensics. The secondary technical pillar is Applied Machine Learning, which encompasses security classification, uncertainty calibration, and open-set recognition. This component also includes experimental measurement and reproducible data engineering.

1.2 Literature Review

1.2.1 Review scope and search method

The review covers three strands: physical-layer identification of RFID and NFC devices, clone detection as a system-level problem, and the classification, open-set, and calibration methods the component depends on. Each source is examined for method, data, context, findings, strengths, limitations, and influence on C2.

I searched IEEE Xplore, the ACM Digital Library, and Scopus. Search strings combined a device term (NFC, RFID, ISO 14443, contactless smart card) with an evidence term (fingerprinting, physical-layer identification, provenance, clone detection, response timing), and, for the deployability question, a hardware term (commodity reader, PC/SC, Proxmark). We applied backward and forward citation chaining to the survey by Danev et al. [1] and to the NFC study by Lee et al. [5].

1.2.2 Physical-layer identification of RFID and NFC devices

Danev, Zanetti and Capkun [1] provide the conceptual foundation. Their survey defines physical-layer identification as recognition based on device-specific characteristics arising from analog hardware imperfections, and it treats acquisition, feature extraction, matching, attacks, and evaluation assumptions systematically. Its strength is exactly that breadth, and it states the evaluation pitfalls plainly, including the requirement to test across acquisitions rather than within one. Its limitation for C2 is that the scope is signal-level rather than protocol-level. C2 adopts the underlying idea, which is to identify a source from observable behavior, while deliberately not claiming analog RF fingerprinting.

Romero et al. [2] study counterfeit detection for 13.56 MHz ISO 14443 cards using a laboratory test fixture and a real-time oscilloscope with very high sampling capability. The study matters here because it demonstrates that cards differ physically even when the digital information is identical. Its limitation is deployability: the measurement setup is instrumentation-grade. C2 treats [2] as evidence that a physical distinction exists, which is the premise the component rests on, and not as a method that could be installed at a door.

Zanetti et al. [3] collect signals from 70 passive UHF tags with a purpose-built reader and classify them from timing and spectral features. Li et al. [4] propose RCID, fingerprinting passive tags through frequency-dependent wideband backscatter. Both strengthen the argument that manufacturing variation supports anti-cloning evidence. Both operate in UHF, under a different protocol, and rely on specialized acquisition hardware. C2 borrows their measurement discipline and their evaluation motivation while moving to ISO/IEC 14443 protocol-response evidence on HF cards.

Lee, Baek and Kim [5] are the closest NFC-specific prior art. Their testbed pairs an off-the-shelf NFC reader with a USRP X300 software-defined radio, generates 158,620 RF signal samples per tag across 50 tags, and compares fully connected, convolutional, and recurrent networks, reaching a reported 96.16 percent. The strength is direct NFC evidence that same-batch tags are separable. Three limitations bear on the C2 research question. The acquisition chain is an SDR rather than a reader, so the result is not attainable from protocol-level evidence. The task is closed-set identification of 50 known tags, which gives an unfamiliar source no possible output other than a known label. And repeated signal samples from those same 50 physical tags are divided between training and evaluation within one acquisition campaign, so the experiment measures identification of already represented tags rather than generalization to an unseen physical card, and cross-session stability is untested.

1.2.3 Clone detection as a system-level problem

Lehtonen et al. [7] propose clone detection for low-cost tags using a back-end and a mutable synchronized secret. Inconsistency appears when a genuine tag and a clone carrying the same identity are both scanned. The contribution is conceptual as much as technical: it reframes cloning as something to detect rather than only something to prevent. The limitation is that detection depends on writable state and on later observations, so it is not a provenance decision about the source presenting itself now. C2 complements this class of back-end control rather than replacing it.

Garcia et al. [6] establish the security relevance of weak legacy credentials through the dismantling of MIFARE Classic. Their work supports the scope decision taken here. C2 targets legacy and weakly authenticated laboratory credentials, and does not present a source-provenance model as a substitute for sound cryptographic authentication.

1.2.4 Open datasets and protocol context

RFID-ExSim [10] is a recent benchmark containing more than 400,000 raw read events collected with two synchronized ESP32 and MFRC522 readers and twelve passive tags, under baseline, collision, UID-cloning, replay, and flooding scenarios. The released fields include reader ID, local tag ID, hashed UID, payload, scenario, session, distance and orientation. Its strengths are scale, reproducibility, attack diversity, and open organization. Its limitation for C2 is decisive: it does not carry ISO/IEC 14443 protocol-response fields or reader-side response timing, which are precisely the evidence C2 models. A further caution is that the scenario label appears in the filenames and in the event fields, so a classifier trained naively on the released files can learn the label rather than the phenomenon. RFID-ExSim is therefore cited as evidence that event-level clone datasets exist, and not used as training data. I record this decision in Appendix 2.

ISO/IEC 14443-3 [8] and ISO/IEC 14443-4 [9] provide the protocol context. Part 3 covers initialization and anticollision, where ATQA and SAK are defined; Part 4 covers the transmission protocol, where ATS and frame timing belong. They are normative references rather than fingerprinting papers, and they fix terminology and keep the acquisition sequence consistent instead of inventing card-family-specific meanings.

1.2.5 Classification, open-set recognition and confidence

Random Forest [12], Support Vector Machine [13], and k-Nearest Neighbor [14] are selected because the expected C2 dataset is small to moderate, tabular, and heterogeneous rather than image-scale. Random Forest gives nonlinear boundaries with usable feature importance. SVM suits small datasets with scaled features and margin-based separation. KNN provides a simple

local-distance benchmark that also supports the open-set fallback. I include the three for comparison, not for prediction. C2 does not declare a best classifier before the data exist.

Scheirer et al. [11] formalize open-set recognition and define open-space risk as the risk incurred by labeling regions of feature space far from any training data. A closed-set classifier will confidently assign a known label to an input unlike anything it has seen, and ordinary accuracy will not reveal it. This directly justifies the UNKNOWN output and reporting the rejection layer as a coverage-versus-accuracy trade-off. Niculescu-Mizil and Caruana [15] show that raw classifier scores are not calibrated probabilities and evaluate corrections including Platt scaling and isotonic regression. C2 therefore separates classification from confidence calibration, and never displays a raw vote proportion or decision value as a probability.

1.2.6 Comparison of existing approaches

Approach	Evidence and technology	Strength	Limitation relative to C2
Cryptographic strengthening	Stronger challenge-response credentials; legacy weakness shown by [6]	Prevents simple identity duplication where correctly deployed	Needs compatible cards and readers; C2 is an assessment layer for legacy populations, not a cryptographic replacement
Back-end clone detection	Synchronised mutable state [7]	Detects duplicate identity use with low-cost tags	Requires state update and multiple observations; does not assess the source presenting now
ISO 14443 electromagnetic fingerprinting	High-bandwidth oscilloscope and test fixture [2]	Direct evidence of physical differences in HF cards	Instrumentation-grade setup; not a practical acquisition path
UHF physical fingerprinting	Purpose-built reader, timing and spectral features [3]	Manufacturing variation supports identification	Different band and protocol; specialised acquisition
Wideband UHF backscatter	Wideband collector [4]	Large hardware-derived feature space for anti-cloning	Specialised wideband hardware; not ISO 14443 protocol evidence
NFC deep RF fingerprinting	NFC reader plus USRP SDR and deep networks [5]	NFC-specific; 50 tags separated with high accuracy	Requires SDR; same tags contribute samples to training and evaluation; unseen-card provenance untested; closed-set

Approach	Evidence and technology	Strength	Limitation relative to C2
Open event-level dataset	Two MFRC522 readers, over 400,000 events [10]	Open clone, replay and collision data with controlled context	Event-level fields only; no protocol-response provenance evidence; scenario label present in filenames
Proposed C2	Proxmark3 multi-session protocol and timing evidence, grouped ML, open-set rejection	Tests practical reader evidence, unseen physical sources, independent sessions and UNKNOWN handling	May reach lower accuracy than analogue methods; small corpus and reader dependency are explicit limitations

Table 1: Comparison of existing approaches and the evidence behind them.

1.3 Research Gap

Three results are established. Physical differences between RFID and NFC devices are measurable [1]- [5]. Cloning is a real security concern in legacy contactless systems [6], [7]. Low-cost readers can collect large event traces under cloning and replay conditions [10].

It remains unclear whether protocol-response and reader-side timing evidence from a research-grade reader remains discriminative when the test card and test session were both absent from training. The distinction matters because of how the closest NFC study is evaluated. Lee et al. [5] divide a very large number of signal samples produced by the same 50 tags between training and evaluation. That design is appropriate for identifying those enrolled tags, and it says nothing about whether a model trained on some physical cards can assign a provenance class to a card it has never seen. RFID-ExSim [10] supplies attack-event data but not the protocol and timing features the question requires. The open-set literature [11] adds a second unresolved point: a closed-set classifier is incomplete whenever previously unseen sources can appear, and the rate at which a deployment accepts such a source as genuine is what matters.

Statement of the gap. *It is not established whether multi-session NFC protocol-response and reader-side timing fingerprints acquired with a research-grade reader generalize to unseen physical cards under source-aware and session-aware evaluation, nor how such a system behaves when an unfamiliar source should be rejected rather than forced into a known provenance class.*

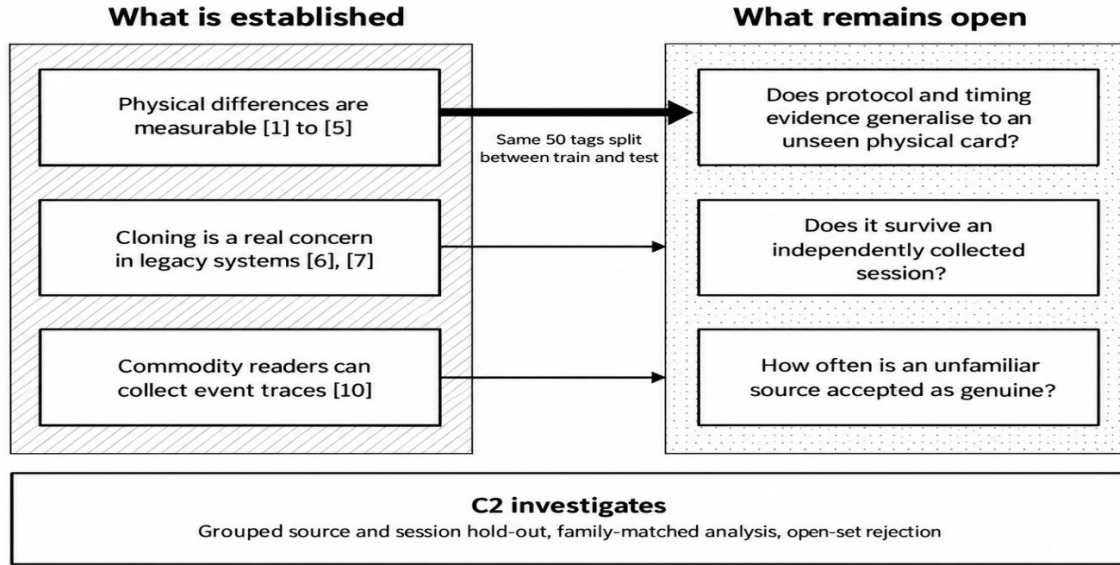


Figure 2: From established evidence to the C2 research gap.

Aspect	Original C2 concept	Revised C2 research design
Acquisition	Repeated measurements, possibly one batch	Independent sessions across separate days, setup rebuilt between them, randomised and interleaved source order
Primary unit	Individual observations	Session-level fingerprint; physical source is the hold-out group
Classes	Original / Clone / Suspicious	Ground truth: Genuine / Clone-like / Emulator. Model output: Original-like / Clone-like / Emulator-like / UNKNOWN
Family control	Not explicit	Within-family primary analysis; chip_type is metadata only and never a predictive feature
Evaluation	Accuracy and F1	Grouped card hold-out, later-session test, FAR and FRR, macro-F1, calibration, open-set rejection, cluster bootstrap intervals
Uncertainty	Every source receives a label	Calibrated confidence plus distance-based rejection
External dataset	Possible training source	RFID-ExSim used only as context and gap evidence, because its fields do not match C2 provenance features

Table 2: Original C2 concept versus the revised C2 research design.

2. OBJECTIVE

2.1 Main Objective

This study aims to determine whether multi-session NFC protocol-response and reader-side timing fingerprints, acquired using a Proxmark3 research reader, can distinguish original-like from clone-like sources under physical-source and session hold-out evaluation. Additionally, the research seeks to quantify the behavior of a calibrated open-set rejection layer when presented with unfamiliar sources.

The primary scientific outcome is the generalization between genuine and clone sources. Emulator-like classification is considered secondary, as only one Flipper Zero device is available, which precludes establishing device-independent emulator generalization. The research objective is intentionally framed as a question rather than a predetermined performance metric, acknowledging that reader-side evidence may ultimately prove insufficient. This result remains publishable and is more defensible than setting arbitrary targets before data collection.

2.2 Specific Objectives

1. SO1. Build and document a family-controlled laboratory corpus of genuine cards, authorized clone-like laboratory copies, and an authorized emulator, with pseudonymous source identifiers and full metadata, holding at least three sources per class within each card family.
2. SO2. Define a non-destructive standard interaction sequence and collect at least ten independent sessions per physical source across at least five separate days, with source order randomized, and classes interleaved within every session.
3. SO3. Construct session-level fingerprints from non-identity protocol behavior, response-timing distributions, authentication outcomes, and within-session stability, while preventing label, source, and preprocessing leakage.
4. SO4. Train and compare Random Forest, SVM and KNN under grouped source-aware and session-aware splits, reporting within-family results together with protocol-only, timing-only and combined ablations.
5. SO5. Implement and validate an open-set rejection mechanism using validation-only threshold selection and calibrated classifier confidence, returning UNKNOWN when the evidence is insufficient.
6. SO6. Evaluate cross-session robustness, unseen physical-source generalization, false acceptance and rejection, calibration, source drift, and emulator-device limitations, with confidence intervals appropriate to grouped data.

3. METHODOLOGY

3.1 Research Methodology and Design

The methodology is a quantitative controlled laboratory measurement study with repeated measures and a multi-session design, followed by supervised machine learning and open-set evaluation. The design follows from the question. Measurable differences between physical and protocol source classes require known ground truth and repeatable laboratory control. Simulation cannot produce the hardware-dependent response variation that is the object of study, and uncontrolled field data would make provenance labels and confounds impossible to verify.

The data are hierarchical. Repeated interactions nest inside sessions, and sessions nest inside physical sources. Individual observations are therefore not independent, and treating them as such is the error this design exists to avoid. C2 uses the session fingerprint as the modeling row and the physical source as the primary grouping variable for evaluation. A card held out for testing is never represented in any training row.

3.2 Data, Participants and Experimental Inputs

3.2.1 Physical corpus and class design

All C2 measurement data are primary data generated by hardware owned by, or explicitly authorized for, the project. No bank, transport, campus, employee or third-party access credential is copied, emulated or used for data collection.

The corpus spans five technology families, and they do not all play the same role. MIFARE Classic 1K and NTAG21x have widely available rewritable-identifier test media so that a clone-like counterpart can be prepared within the family and provenance can be tested with the family held constant. DESFire EV1 and EV2 use AES or 3DES mutual authentication and no equivalent test media exists, so no clone-like counterpart is obtainable for them. Ultralight has test media but too few sources for a within-family split. The corpus is therefore partitioned: two families form the family-matched provenance core, and three form an open-set probe set withheld entirely from training, where the correct verdict is UNKNOWN. Families that cannot supply a clone are exactly the families that test whether the system refuses unfamiliar evidence.

Class	Family	Sources	Role	Control that matters
GENUINE	MIFARE Classic 1K	10	Provenance core; grouped source hold-out	Production batch recorded per source
CLONE	Classic-compatible test media	At least 6, from at least 3 variants	Provenance core; grouped source hold-out	Variant is metadata only, so media type cannot stand in for class
GENUINE	NTAG215	10	Provenance core; grouped source hold-out	Production batch recorded per source
CLONE	NTAG21x-compatible test media	At least 6, from at least 3 variants	Provenance core; grouped source hold-out	As above
EMULATOR	Flipper Zero	1 device, at least 4 declared configuration pseudo-sources	Emulator class, with a stated generalisation limit	One device is never counted as several; results reported with and without this class
GENUINE, unseen	MIFARE Ultralight	2	Open-set probe; withheld from all training and threshold selection	Too few sources for a within-family split
GENUINE, unseen	DESFire EV1	2		No clone-like counterpart obtainable
GENUINE, unseen	DESFire EV2	2		EV1 and EV2 are separate families, not pooled

Table 3: Physical corpus, class design and the role of each family.

The family-matched design is essential, not decorative. If every genuine card were an NTAG215 and every clone a Classic-compatible test card, a classifier would learn the family and never touch provenance. Results are reported per family first; cross-family pooling is a secondary analysis in which family is a stratification variable, never a predictor. The clone-like floor of six per family comes from the split, not preference: leave-one-source-out must still leave a usable training set. Drawing them from three variants prevents the clone class collapsing into one chip type.

The emulator class carries the weakest sampling and the proposal states this plainly. One physical emulator cannot separate emulator provenance from this device's characteristics. Declared configuration pseudo-sources permit a grouped split within the class, but they share one antenna and one silicon substrate, so every emulator result is reported both with and without the class and the conclusion is framed as a single-device finding

3.2.2 Acquisition technologies and their selection

Acquisition is tiered so that dependency on specialist hardware is measured rather than assumed. The Proxmark3 RDV2 512k is the primary reader for protocol traces and reader-side response timing. It is a research reader suitable for controlling ISO/IEC 14443 interaction and repeatable scripting, and it sits much closer to a practical reader than the oscilloscope and SDR setups in [2]-[5]. It is not an analog RF instrument and is not treated as one; its timing resolution and repeatability are characterized in a pilot study before claiming any fine-grained timing effects. The Flipper Zero is owned and serves as the authorized emulator source and secondary protocol observer. An ACR122U or similar PC/SC reader is a protocol-only contingency; host-side timing there is affected by USB and operating-system jitter and is never presented as equivalent.

The probe families change what each tier can observe. DESFire authentication is a multi-step exchange rather than a single challenge, so the authentication group carries more structure for those families. The Proxmark3 observes the full exchange and its inter-frame timing; a PC/SC reader can issue the APDUs and see the outcome, but host-level timing of a multi-step exchange is dominated by USB scheduling, so that structure is lost. Experiment E1 quantifies this rather than assuming it. The analysis stack is Python with pandas, scikit-learn and Jupyter, version-locked, with all preprocessing fitted inside training folds.

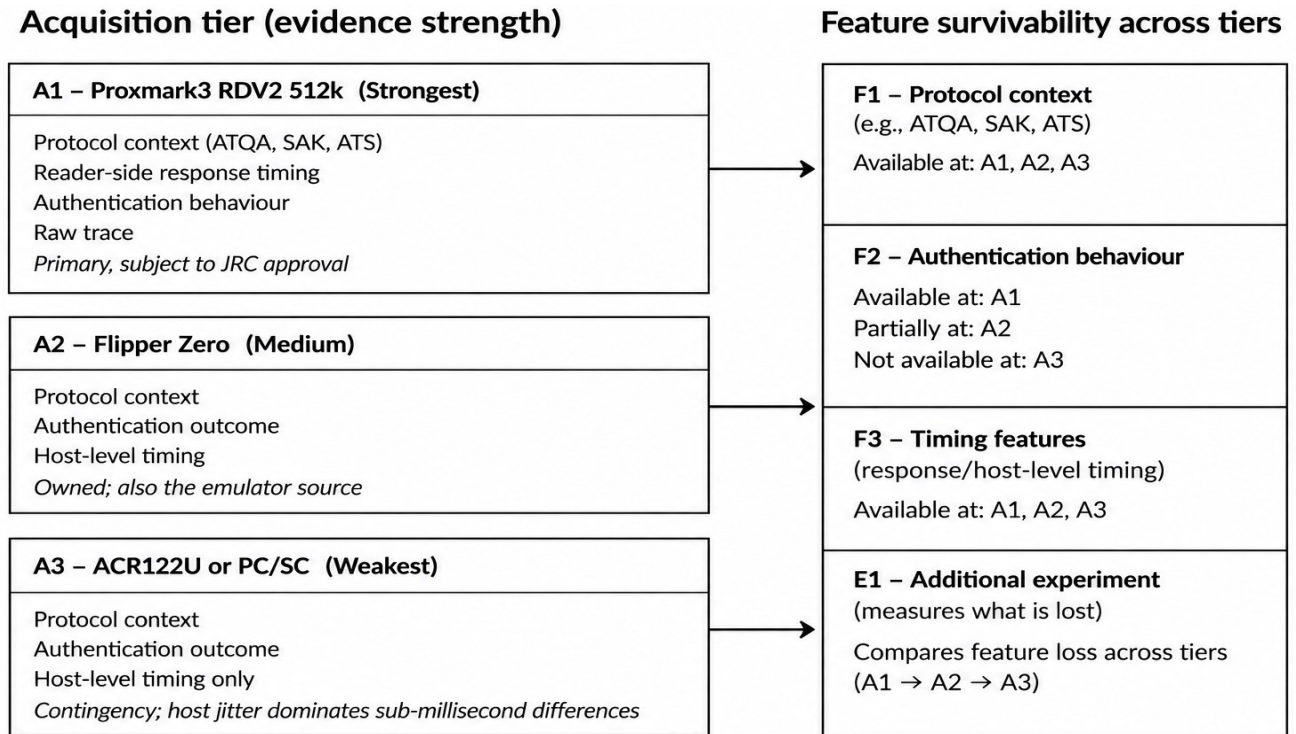


Figure 3: Acquisition tiers and the evidence available at each tier.

3.2.3 Standard interaction and session protocol

Each family is measured with a fixed, non-destructive sequence built on standards-compliant discovery and selection with read-only capability checks, recording protocol context, response timing and authentication outcomes only where the family legitimately supports them. Because the corpus spans five families with different capability sets, the sequence is family-specific by design, and I record the variant used with every observation. The proposal contains no operational instruction for duplicating third-party credentials; clone-like sources are prepared solely from project-owned cards under the approved procedure.

A session is an independently reconstructed collection period. The central threat is confounding, not noise: if every genuine card is measured on Monday and every clone on Wednesday, any classifier separates them by learning Wednesday. Each session therefore contains sources from all available classes and every family scheduled that day; source order comes from a recorded random seed; each card is lifted and repositioned between trial blocks; and a positioning jig fixes nominal distance and orientation. Sessions are scheduled one per day per source, not several per day, because same-day sessions share ambient conditions and a single setup build, so the day effect cannot be separated from the session effect that experiment E2 depends on.

These controls are testable rather than declared. Because session identity and collection date are both recorded, a diagnostic classifier can be trained to predict the session, and separately the day, from the fingerprint features. If either is highly predictable, that signal is strong relative to the class signal and the provenance result must be read in that light. Both diagnostics are reported whatever they show.

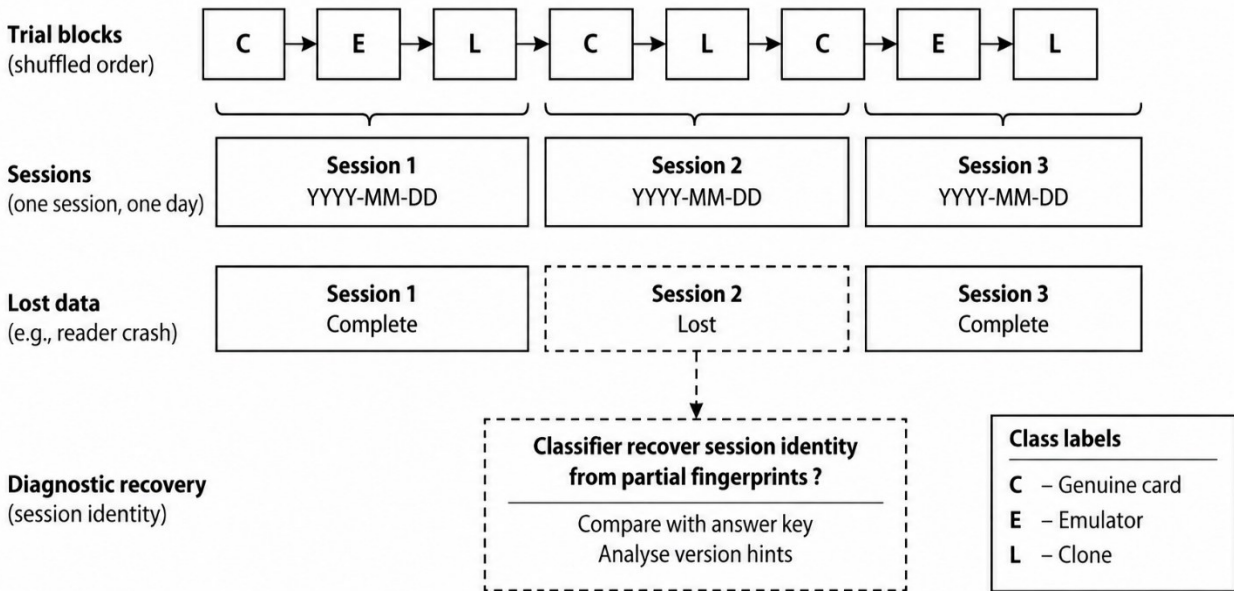


Figure 4: Controlled multi-session acquisition protocol designed to minimise session- and positioning-related confounding.

3.2.4 Target sample size

The project is constrained by the number of physical sources, not by the number of repeated reads. Thousands of reads from a handful of cards do not create thousands of independent devices, and treating them as such is the leakage this design exists to prevent.

A very high repeated-read target, on the order of a hundred thousand reads per family, was considered during planning on the basis that the cards are rewritable, and was rejected. Protocol context is deterministic per card model, so repeated protocol reads of one source return the same response and add no variance to sample. Rewriting a card changes its stored data but not its antenna geometry, capacitance, or silicon characteristics, so a rewritten card is the same physical source. Sampling effort is therefore allocated to timing and authentication behaviour, where genuine between-source and between-session variance exists. I record the decision in Appendix 2.

Quantity	Target	Reason
Physical sources, core	32 cards: 10 genuine and at least 6 clone-like per family, across two families	Supports grouped source hold-out inside each family, not only across the pooled corpus
Physical sources, probe	6 cards: Ultralight, DESFire EV1, DESFire EV2, 2 per family	Supplies genuinely unseen families for E4; no clone-like counterpart is obtainable for DESFire
Emulator hardware	1 owned Flipper Zero, at least 4 declared configuration pseudo-sources; a second device is a stretch goal, not assumed	Permits a grouped split within the emulator class without counting one device as several
Sessions, core sources	10 per source, one per day, across at least 10 days	Supports cross-session stability and train-early, test-later evaluation, and separates day from session
Sessions, probe sources	5 per source, one per day	Probe sources appear only at evaluation; the reduced count is reported, not hidden
Interactions per session	50, as a fixed floor	Stabilizes median, IQR, CV and related timing features. A fixed count stops interaction volume becoming a covariate that varies with class or session
Session-level modelling rows	Approximately 390: about 360 cores, about 30 probes	Still a small-data regime, so grouped cross-validation, simple models and confidence intervals remain mandatory
Raw observations	Approximately 19,000 to 20,000	The evidence corpus from which fingerprints are derived, not independent ML rows

Table 4: Target sample sizes.

Source count, not fingerprint count: within one family, the grouped hold-out draws on sixteen sources, so a source-level bootstrap interval on accuracy is expected to span roughly fifteen to twenty-five percentage points. The study is designed to establish whether an effect exists and whether feature groups differ, not to report a deployable accuracy figure.

Core class counts are unbalanced, at twenty genuine sources against at least twelve clone-like and four emulator pseudo-sources, so performance is reported with macro-averaged metrics and per-class breakdowns rather than overall accuracy, with class weighting applied inside training folds. Headline metrics carry bootstrap confidence intervals resampled at the source and session level; cross-validation is repeated across several seeds, with across-seed variance reported, and no claim is made about differences that fall within the intervals.

3.2.5 Canonical dataset structure

Field	Level	Use and rule
observation_id	Observation	Unique interaction record
session_id	Observation	Independent acquisition session
collection_date	Session	One session per source per day is the protocol. Read by the split generator and the day-predictability diagnostic, so a same-day duplicate is a detectable deviation
physical_source_id	Observation	Pseudonymous card or device identifier; the grouping key for hold-out
pseudo_source_id	Observation	Declared emulator configuration group, distinct from physical_source_id. Grouped splits within the emulator class use this field; all reporting states these are configuration pseudo-sources of one device
source_class	Label metadata	GENUINE, CLONE or EMULATOR; never a predictive feature
card_family	Metadata and stratification	MIFARE Classic 1K, NTAG215, MIFARE Ultralight, DESFire EV1 or DESFire EV2. Used to build family-matched splits, never as a primary feature. EV1 and EV2 are distinct values and are not pooled
family_role	Metadata	CORE or PROBE. A PROBE source is excluded by the split generator from every training and threshold-selection fold. Enforced in code, not by convention
clone_available	Metadata	TRUE or FALSE per family. Documents why no clone-like counterpart exists for the DESFire families, so the absence is not read as an oversight
chip_type	Metadata only	Specific test-media type; excluded from the feature matrix

Field	Level	Use and rule
acquisition_tier	Metadata	A1, A2 or A3; records which reader produced the observation
protocol_response_fields	Observation	ATQA, SAK and ATS presence and structure, or family-specific capability response. Static identity fields are excluded from the primary provenance model
response_timing	Observation	Reader-side timing for the standard interaction; unit and timing source documented explicitly
auth_context, auth_outcome	Observation	Records exchange depth as well as outcome, because the DESFire families use multi-step mutual authentication rather than a single challenge. Unsupported conditions are explicit N/A, never zero
trial_no	Observation	Repeated interaction order within the session
reader, firmware, host, script_version	Observation and session	Reproducibility and drift metadata
split_assignment	Separate split file	TRAIN, VAL or TEST by source group; the final test set is never used for model or threshold tuning

Table 5: Canonical dataset schema.

Leakage hygiene goes further than dropping the class column. Filenames carry no class names. Scaler parameters, imputation, feature selection, and hyperparameter tuning are fitted only inside training folds. I freeze final test source identifiers before the final model comparison, and choose threshold and calibration parameters from training and validation data alone. Raw and processed datasets are versioned so every result can be regenerated from the raw records and registries, with no manual editing.

3.2.6 Session fingerprint feature groups

Repeated observations inside one session are aggregated into a single fingerprint row across five groups. F1 captures protocol behavior: presence and structure of supported responses, response lengths, status patterns, and capability behavior, with UID and obvious static identity values excluded so the classifier cannot memorize identity. F2 captures the timing distribution: mean, median, standard deviation, IQR, minimum, maximum and coefficient of variation. F3 captures authentication behaviour where the family legitimately supports it. F4 captures within-session stability, the dispersion of F1 to F3 across repeated interactions. F5 captures cross-session stability: the distance between a source's current session and its previous sessions.

The five-family corpus makes the encoding of unsupported capabilities a first-order concern. Families differ systematically in which features they even define: the DESFire families support multi-step mutual authentication that Classic and NTAG do not. If an unsupported condition were encoded as zero, the missingness pattern alone would identify the family and a classifier could recover family membership from a matrix that was supposed to exclude it. Unsupported conditions are therefore explicit N/A indicators, and family-matched analysis runs within a family so the missingness pattern is constant across the sources compared. Any pooled analysis reports the missingness pattern alongside the result.

F5 carries a constraint that is easy to miss. Cross-session stability requires prior sessions from the same source, and those do not exist for a genuinely unseen source at decision time. The deployment-compatible fingerprint is therefore F1 to F4, and F5 is excluded from every experiment in which the test source has no history, including every experiment involving the probe families. I report the two settings separately rather than pooling them.

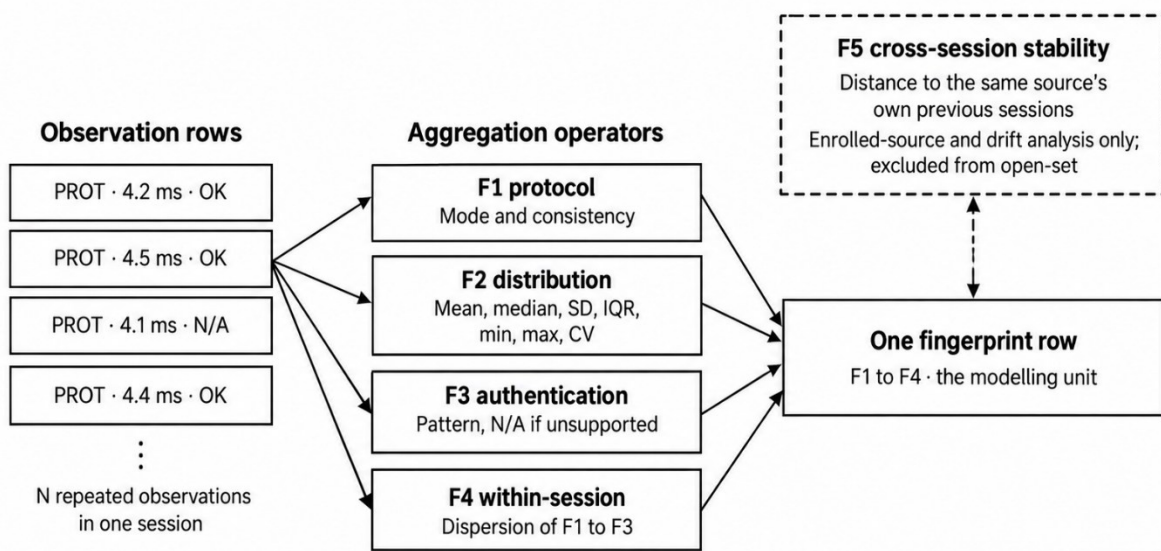


Figure 5:. Session fingerprint construction from repeated observations.

3.2.7 Ethics and safety

No human participant is required for the core hardware measurement experiment. The stakeholder discussions in Section 5 are requirements-validation activities and will follow institutional consent and ethics procedures if conducted. Ethics clearance from the SLIIT Research Ethics Committee is required before hardware experimentation begins, and JRC approval is required for the Proxmark3.

Every credential experiment uses owned or explicitly authorized laboratory media. No third-party credential, recovered third-party key, real access-control bypass, payment credential, or transport credential is used at any point. The DESFire families require a specific statement because they are cryptographically protected: the project uses only project-owned DESFire cards under keys set by the project, attempts no key-recovery technique against any card, and observes these families rather than duplicating them. Published data use pseudonymous aliases and exclude secret material. The paper describes preparation of clone-like sources at the level needed to reproduce the measurement, not as a duplication guide. The purpose is defensive detection research and reproducible measurement.

3.3 Baselines and Ablations

I run seven comparisons under identical grouped splits and preprocessing, so differences between them mean something. B1 is a static identity and family diagnostic, using UID, static identity values, and obvious card-family fields, run only to establish how much separability is trivial information rather than provenance. B2 uses protocol behavior alone (F1) and answers what can be learned without timing. B3 uses timing alone (F2). B4 combines protocol and timing (F1 and F2). B5 is the full deployment-compatible model (F1 to F4) and serves as the primary model for held-out and unseen-source experiments. B6 repeats B5 features under a naive split that ignores physical-source grouping. B7 adds F5 for sources with history, measuring the benefit and limits of cross-session evidence for already enrolled sources.

The comparison that matters most is B6 against the grouped source-aware evaluation. If B6 reports substantially higher performance, the difference is a direct measurement of how optimistic a result becomes when the same source can appear on both sides of the split. The proposal does not claim in advance that this difference will be large. It is measured, and B6 remains a diagnostic rather than a headline result, whatever it shows.

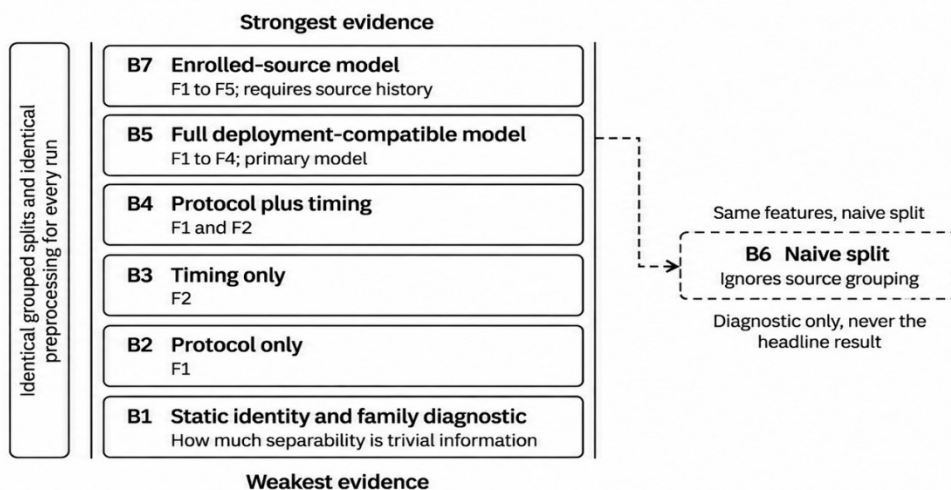


Figure 6: Evaluation ladder - baselines, ablations and grouped splits.

3.4 Evaluation Metrics

Metric	Why it is relevant	Reporting rule
Genuine-versus-clone F1	The provenance decision the component actually makes, independent of the emulator class	Primary scientific result
Macro-F1	Balances class performance in the multiclass setting	Reported with and without the emulator class; the emulator-inclusive score is never the only headline number
Per-class precision and recall, confusion matrix	Shows where errors concentrate across genuine, clone and emulator decisions	Reported by family as well as pooled where valid
False Acceptance Rate	Measures a non-genuine source accepted as Original-like, which is the costly error	Reported at each selected operating point with a confidence interval
False Rejection Rate	Measures a genuine source rejected or labelled non-genuine	Reported alongside FAR; drives usability and the drift analysis
Held-out physical-source performance	Tests class-level generalization rather than device memorization	Test sources absent from training; the drop from in-sample performance is reported explicitly
Cross-session consistency	Checks whether a verdict changes across independent sessions	Per-source agreement rate and later-session performance
Unseen-source acceptance rate	The open-set failure mode, and the quantity the closed-set literature omits	Proportion of final unseen sources accepted as a known class, especially as Original-like
Coverage versus accuracy	The rejection layer trades answered queries against correctness	The full curve is the result; the dashboard operating point is marked on it and justified
Brier score and reliability diagram	Displayed confidence must match held-out correctness [15]	Reported before and after calibration
Session-predictability diagnostic	Measures how strongly session identity is encoded in the features, which is the confound check	Reported whatever it shows; the provenance result is interpreted in light of it
Cluster bootstrap confidence interval	Reflects the grouped structure of the data	Resamples physical sources and sessions, never individual repeated observations

Table 6: Evaluation metrics and reporting rules.

No absolute accuracy target is promised before the data exist. Success is defined by transparent comparison against baselines, confidence intervals, held-out source generalization, and defensible error analysis. A negative result, for instance, timing features that do not generalize, remains a valid research outcome provided the measurement resolution and the evaluation design are reported correctly.

3.5 Validation Strategy

ID	Experiment	Design	Research question
E1	Feature ablation and contingency measurement	B2, B3, B4 and B5 under identical grouped splits, with acquisition_tier recorded	Which evidence groups carry stable provenance information, and what remains available without the Proxmark3?
E2	Cross-session robustness	Train on earlier sessions, test on later independent sessions, with no test session entering preprocessing	Does the fingerprint survive changes of day and setup?
E3	Held-out physical source	Leave-one-source-out or grouped k-fold by physical_source_id within family	Does the model generalize to a physical card it never saw in training?
E4	Open-set unseen source	Final unseen sources reserved from all model and threshold selection; thresholds tuned only through development-source pseudo-unknowns	Can the system refuse unfamiliar evidence instead of forcing a class?
E5	Genuine drift and false rejection	Repeated genuine sessions across days and setup rebuilds	How often does a genuine source become non-genuine or UNKNOWN through drift alone?
E6	Family-matched provenance	MIFARE and NTAG family analyses run separately	Is the performance real provenance evidence rather than card-family discrimination?
E7	Emulator limitation test	Emulator-inclusive and emulator-excluded results reported; if a second physical emulator becomes available, one device is held out	Has the model learned emulator provenance, or only this one Flipper Zero?

Table 7: Validation experiments E1 to E7.

3.5.1 Open-set mechanism

The open-set layer is a rejection mechanism wrapped around the supervised classifier, not a fourth training class. The ground-truth training classes remain Genuine, Clone-like, and Emulator. UNKNOWN means that the presented evidence falls outside the validated support of the known classes.

- Preprocessing and classifier training are fitted only on the training groups. Class probabilities are calibrated on grouped validation data using Platt scaling or isotonic regression as appropriate [15].

- A class-conditional distance is computed from the presented fingerprint to the predicted class training distribution. Because the corpus is small, I use a regularised or diagonal covariance when a full Mahalanobis covariance is unstable, and a KNN distance ratio as the documented fallback.
- We select rejection thresholds on development data alone. Pseudo-unknown validation is created by temporarily holding out development sources, so the final E4 unseen sources stay untouched until the final evaluation.
- The verdict is UNKNOWN when calibrated confidence is too low, or the distance to the predicted class is too large. The two conditions are combined so that either form of weak evidence triggers rejection.
- Results are reported as coverage versus accuracy and as FAR and FRR across thresholds, rather than at one convenient operating point.

I considered two alternatives and set them aside. A one-class model per known class needs more data per class than this corpus will provide. I retain a nearest-neighbor distance-ratio test as the documented fallback if the covariance estimates prove unstable at this sample size. The decision is recorded in Appendix 2. No absolute accuracy target is promised before the data exist. Success is defined by transparent comparison against baselines, confidence intervals, held-out source generalization, and defensible error analysis. A negative result, for instance, timing features that do not generalize, remains a valid research outcome provided the measurement resolution and the evaluation design are reported correctly.

3.6 Development Approach

Iterative prototyping is the selected approach for a reason specific to this component. The acquisition layer is built first and then frozen: schema, measurement script, session checklist, and positioning method must stabilize before the first formal session, because changing any of them midway makes collected sessions incompatible with those that follow, and ten sessions per source across at least ten days cannot be re-collected inside the semester.

The modeling layer has the opposite change profile. It is exploratory and iterates over ablations, split strategies, calibration and rejection thresholds once the dataset is assembled. The approach must therefore accommodate a frozen upstream and an iterative downstream at once. Two-week supervisor review cycles provide the cadence; Git provides the reproducibility record.

4. HIGH-LEVEL SYSTEM ARCHITECTURE

4.1 Overview of the Proposed Solution

The proposed research introduces an NFC Card and Tag Security Enhancement Framework Using Hybrid Detection that combines four independent but complementary components: C1 - NFC Security Profile Scoring, C2 - Multi-Session Protocol-Response Provenance Fingerprinting, C3 - NFC Tag Data Integrity Verification, and C4 - Hybrid Behavioral Anomaly Detection. Each component addresses a different NFC security problem while contributing to a unified assessment.

The framework begins with authorized NFC cards and tags, with data collected through a shared acquisition layer using devices such as Proxmark3 RDV2, Flipper Zero, and ACR122U. After preprocessing, the collected evidence is provided to the four components in parallel, where each component performs its analysis independently and produces a component-specific result.

Finally, the system stores the outputs in a shared backend and presents them through a unified dashboard and reporting layer. This architecture maintains component independence while providing an integrated view of NFC card and tag security.

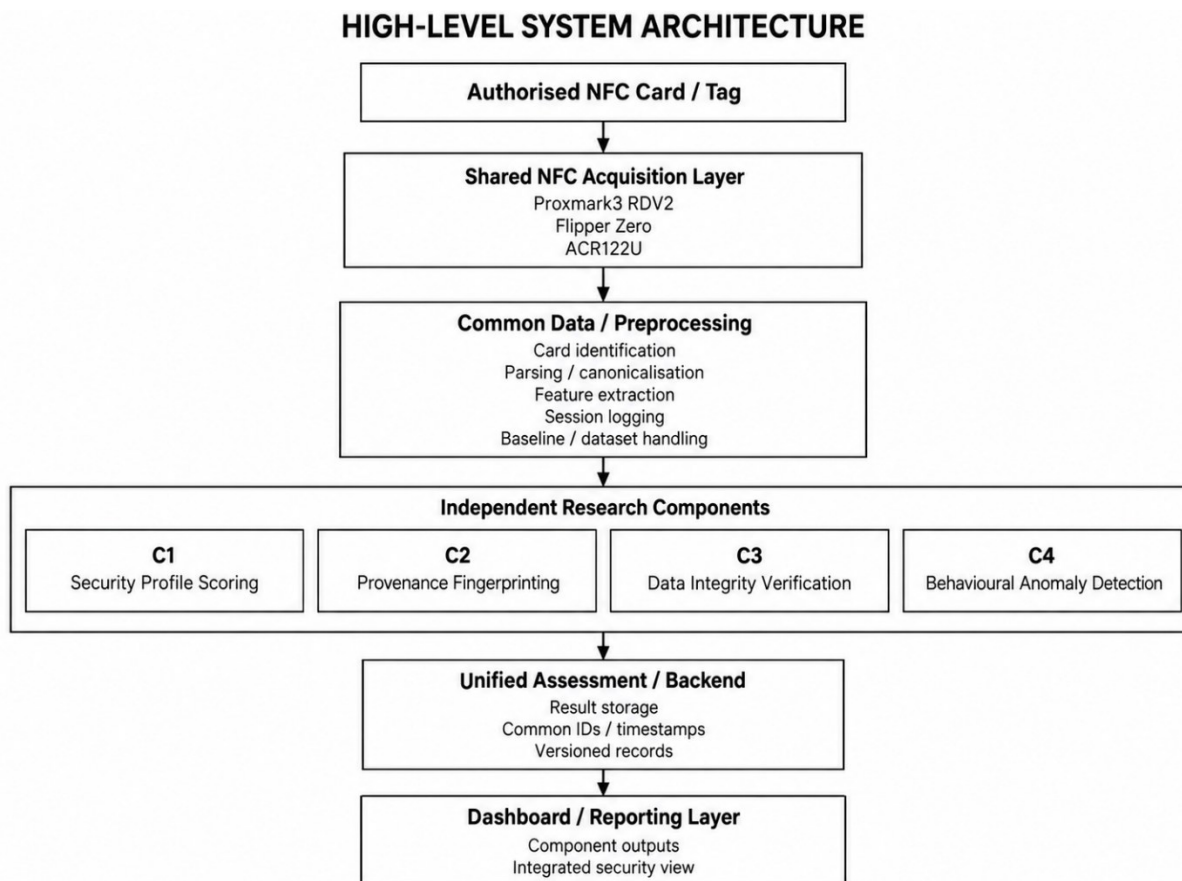


Figure 7: High-level architecture of the four-component framework.

4.2 C2 Internal Architecture

C2 runs two paths. The learning path registers authorized sources, collects independent sessions, canonicalizes observations, builds session fingerprints, freezes grouped splits, trains candidate classifiers, calibrates confidence, and selects rejection thresholds. The verification path collects a short standard session from the presented source, constructs the F1 to F4 fingerprint, obtains the classifier output, applies the open-set checks, and exports the provenance verdict together with calibrated confidence, an evidence summary, and the model version.

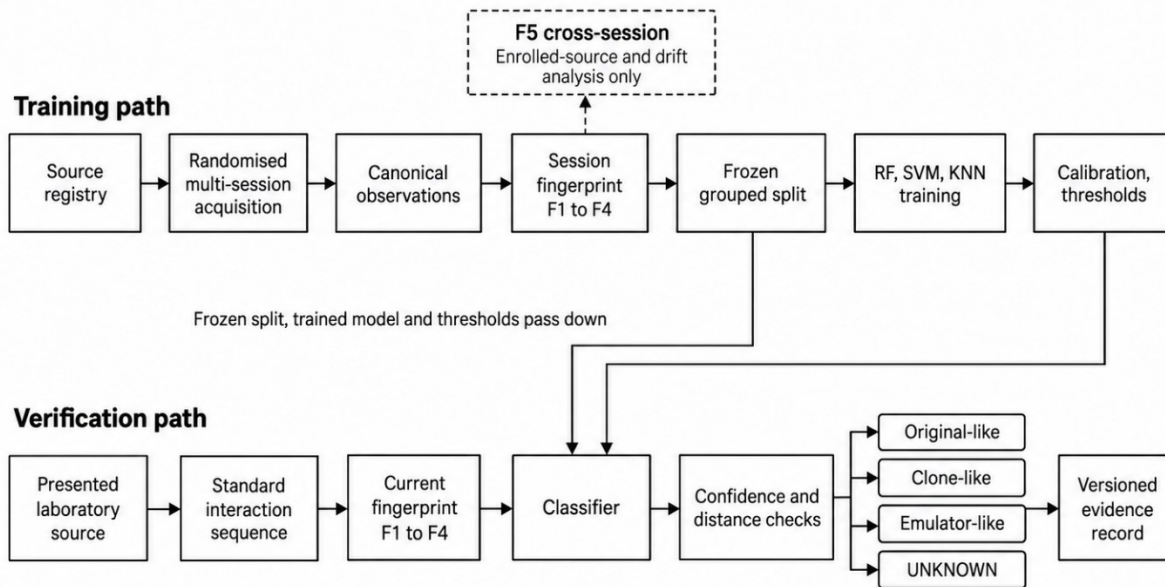


Figure 8: C2 internal workflow, training path and verification path.

4.3 Overall Integration

Integration is data-based rather than tightly coupled. Each component writes a versioned result record keyed on the same credential alias and scan, or session timestamp, and the unified layer joins those records. C2 does not depend on C1, C3, or C4 at runtime. That choice is deliberate: it prevents one member component from becoming a hidden dependency inside another member's research evaluation, which is a common way for a group project to fail one student because another fell behind.

One dependency is real and cannot be designed away. Proxmark3 and the Flipper Zero are shared across components and depend on the same JRC approval, so booking and approval must be coordinated. C2 holds priority during its collection window, because ten sessions per source across five or more days cannot be compressed into one late laboratory week.

4.4 Individual Responsibility Boundary

Activity or deliverable	C2 owner	Shared	Other component
C2 research design, gap and methodology	Yes		
C2 source registry and family-controlled corpus	Yes	Procurement where hardware overlaps	
Standard interaction sequence and session protocol	Yes	Hardware approval coordination	
C2 multi-session data collection	Yes		
Canonicalization and session fingerprint builder	Yes		
Grouped split design and leakage controls	Yes		
RF, SVM and KNN comparison and ablations	Yes		
Open-set rejection and confidence calibration	Yes		
Experiments E1 to E7 and evidence export	Yes		
Ethics clearance and JRC hardware request		All four members	
Shared laboratory hardware scheduling		All four members	
Dataset naming, schema and version convention		All four members	
Unified output schema		All four members	
Configuration and capability scoring			C1 owner
Tag data-state integrity verification			C3 owner
Behavioral anomaly detection			C4 owner

Table 8: Individual responsibility boundary.

The group members recorded in the project AI agreement are Anulasha K.A. (IT23139480), Anjana I.K.D. (IT23160620), A.M.S.K. Abekoon (IT23403642) and Perera L.M.D. (IT23404182).

5. USER REQUIREMENTS

5.1 Requirements Elicitation and Evidence Status

The proposal template asks for evidence from interviews, observation, surveys, workshops, stakeholder discussions, or domain experts. No completed interview transcript, survey result, or signed observation record existed when this draft was written, so this draft presents no user evidence as collected. The requirements below are provisional research and product requirements derived from the documented limitations in Section 1.2, and they will be validated through stakeholder consultation before any product claim is made.

The planned minimum is three semi-structured discussions: a campus or facilities access-control administrator, a cyber-security practitioner or auditor, and an access-control integrator or technician. The question set asks what evidence they would need to act on a suspected duplicate, how they would handle an UNKNOWN outcome, what false-rejection behavior is tolerable at a door, and whether periodic audit or real-time verification is more practical to deploy. The false-rejection question matters most, because the answer is what justifies the operating point chosen on the coverage-versus-accuracy curve. Appendix D holds the question set.

Until that validation happens, the requirements are phrased around measurable research behaviour: traceability, uncertainty, reproducibility, response time, data privacy and evidence export.

5.2 Functional Requirements

ID	Requirement
FR1	The system shall register every laboratory source under a pseudonymous <code>physical_source_id</code> and shall exclude raw UID and secret material from published outputs.
FR2	The system shall execute a documented, non-destructive, family-specific interaction sequence and record protocol, timing and authentication evidence where the family supports it.
FR3	The system shall record reader, firmware, host, script version, session identifier and acquisition tier for every observation.
FR4	The system shall aggregate repeated observations into one versioned session fingerprint conforming to the documented F1 to F4 schema.
FR5	The system shall keep <code>source_class</code> , <code>chip_type</code> , raw identity values and the final test assignment out of the predictive feature matrix.

ID	Requirement
FR6	The system shall classify an eligible session fingerprint as Original-like, Clone-like or Emulator-like, and shall support UNKNOWN rejection.
FR7	The system shall display calibrated confidence and supporting evidence, and shall not display a raw classifier vote as a probability.
FR8	The system shall encode unsupported or missing fields explicitly as N/A rather than as zero.
FR9	The system shall load versioned model, scaler and threshold artefacts and record their versions in every decision.
FR10	The system shall export C2 decisions and supporting evidence in a documented CSV or JSON structure for integration with the group framework.
FR11	The system shall regenerate processed datasets, fingerprints, figures and evaluation tables from raw data and committed scripts, with no manual editing of numeric results.
FR12	The system shall support separate within-family evaluation so that card family cannot silently substitute for provenance class.

Table 9:Functional requirements.

5.3 Non-Functional Requirements

ID	Category	Measurable requirement
NFR1	Response time	A live verification shall target completion within 10 seconds for a short acquisition plus decision. The achieved median and 95th percentile are reported rather than assumed.
NFR2	Reliability	Cross-session verdict consistency shall be measured per source. No absolute consistency percentage is promised before pilot data exist.
NFR3	Reproducibility	Every final metric and table shall be reproducible from raw data, the split file and a committed script, with environment versions and random seeds recorded.
NFR4	Security and privacy	No third-party credential data, recovered third-party key or real access-control secret shall appear in the research dataset or in any publication.
NFR5	Usability	The dashboard shall show the verdict, calibrated confidence, UNKNOWN where applicable, the deviating evidence groups and a short limitation message, in language that does not require machine learning knowledge.
NFR6	Auditability	Every decision shall record model version, scaler version, threshold version and dataset schema version.

ID	Category	Measurable requirement
NFR7	Portability	The analysis pipeline shall run on Windows and Linux using Python 3.10 or later with open-source dependencies only.
NFR8	Maintainability	Adding a card family shall require a new family interaction and schema configuration, not a rewrite of the modelling pipeline.
NFR9	Fair evaluation	All classifier comparisons shall use identical grouped splits and identical preprocessing rules.
NFR10	Data integrity	Raw acquisition files shall be append-only. Processed files shall be regenerated from raw records rather than manually overwritten.

Table 10:Non-functional requirements.

6. COMMERCIALIZATION PLAN

6.1 Target Market and Customer Persona

The near-term target is not per-door replacement. It is a security audit and enrolment assessment service for organizations running legacy contactless credentials who need evidence to prioritize migration or to investigate a suspicious credential. Candidate sectors include universities, hospitals, corporate campuses, hotels and other controlled facilities.

The primary persona is the security or facilities manager who has been told the cards can be cloned, has priced the replacement program, and cannot justify it. What that person needs is a detection layer that sits in front of the existing population. The secondary persona is the security assessor or incident investigator who needs a reproducible provenance result with explicit uncertainty, suitable for a report.

6.2 Value Proposition

C2 adds a provenance-evidence layer to an existing legacy credential population without replacing cards or readers, and without claiming to replace cryptographic authentication. Its differentiators are source-aware evaluation, explicit UNKNOWN rejection, calibrated confidence, and an auditable evidence record. The claim is deliberately bound. Original-like evidence is consistent with the enrolled source class, not cryptographic proof of physical identity, and the product says so.

6.3 Revenue Model

- Periodic credential-population audit: enroll a sample or the full population and identify sources whose provenance evidence warrants investigation or replacement.
- Incident support: controlled remeasurement and an evidence report following a suspected duplicate-credential event.
- Integration licensing: the provenance engine and evidence schema packaged for an access-control vendor or a security consultancy, after validation.
- Open research release: non-sensitive methodology and evaluation code published, which reproducibility requires in any case, with deployment packaging and IP decisions subject to SLIIT policy.

6.4 Cost and Pricing Strategy

Pricing is cost-plus and value-informed, not based on an unsupported market-size claim. A practical quote would combine a laboratory or on-site day rate, an enrolment volume component, and optional integration and reporting fees, benchmarked against the cost of the replacement program the service defers. An audit that identifies which cards actually need replacing costs a fraction of replacing them all.

Two cost drivers are real and are stated rather than glossed over. Enrolment labor scales with the size of the credential population, because every credential must be measured across several sessions before it can be verified. Each verification point needs a reader capable of the measurements the method depends on. The realistic near-term product is therefore a periodic audit service rather than a per-door real-time deployment.

6.5 Competitive Advantage and Commercial Risks

Three advantages are defensible. Deployability: unlike the analog methods in [2]-[5], the approach requires no specialized instrumentation. Honest uncertainty: the open-set layer and calibrated confidence separate the product from tools that always return an answer. Published leakage-safe evaluation: the reported performance is obtained under source-aware and session-aware hold-outs, which a technically literate buyer can tell apart from a randomly split figure.

Four assumptions underlie the plan, and each carries a validation action. That some organizations prefer audit and triage to full replacement, which the stakeholder interviews test directly. That practical reader evidence is more deployable than oscilloscope or SDR fingerprinting, which the prototype demonstrates by quantifying the accuracy loss against the literature ceiling rather than claiming equivalence. That UNKNOWN and calibrated confidence improve operator trust, which

the interview protocol's usability question tests. And that a small training corpus may limit transfer to a new site or card batch, which is an acknowledged methodological limitation addressed through per-site enrolment and, in future work, a multi-site dataset.

6.6 Intellectual Property Considerations

- Proxmark3 and Flipper Zero firmware and all third-party libraries carry their own licenses, and derived code inherits those terms.
- MIFARE and NTAG are NXP product names, used here only to describe technology families. The work must not imply endorsement or affiliation.
- Code, dataset licensing and any commercial packaging remain subject to SLIIT intellectual-property rules. Confirm the institutional position before any commercial commitment.
- Published datasets must exclude secrets and raw third-party identifiers and must document permitted research use. A permissive open-source license for code and CC BY for the dataset is consistent with the reproducibility requirement.

7. BUDGET AND JUSTIFICATION

The C2 budget is based on the shared hardware and software resources available within the overall NFC Card and Tag Security Enhancement Framework. Although these resources are shared across the wider research project, this section explains their specific relevance to C2 - Multi-Session Protocol-Response Provenance Fingerprinting.

C2 requires repeatable NFC interaction data collected across multiple controlled sessions. The main costs therefore relate to NFC acquisition hardware, authorized test cards, and supporting analysis tools. Most software used for data processing, feature extraction, statistical analysis, and machine-learning evaluation is free or open source.

Item	Category	Estimated Cost (LKR)	C2-Specific Justification
Proxmark3	Research Hardware	25,000	Primary reader for repeated protocol-response and timing acquisition.
Flipper Zero	Research Hardware	80,000	Authorized emulation source for genuine-vs-emulated comparison.
NFC Card Set	Test Media / Consumables	10,000	Multiple authorized card families for repeatable C2 experiments.
Python 3.x	Software	Free	Data processing, feature extraction, and model development.
Pandas / NumPy	Software	Free	Cleans and summarizes repeated session measurements.
scikit-learn	Software	Free	Implements and evaluates RF, SVM, and KNN models.
Jupyter Notebook	Software	Free	Exploratory analysis and model evaluation.
Proxmark3 Client / Iceman Firmware	Software	Free	Controls Proxmark3 and supports NFC data acquisition.
Git / GitHub	Development Platform	Free	Version control and experiment tracking.
Human Effort	Research Effort	Not monetized	Student-led data collection, analysis, and documentation.

Table 11: Budget and justification.

8. WORK BREAKDOWN STRUCTURE (WBS)

8.1 Task Breakdown and Workload

WBS	Task	Weeks	Owner
1.0	Initiation and evidence completion	1 to 3	C2
1.1	Execute and log the literature search; complete the reference matrix	1 to 2	C2
1.2	Ethics and JRC application; shared hardware coordination	1 to 2	Shared
1.3	Campus and site observational survey for deployment evidence	1 to 3	C2
1.4	Stakeholder requirements interviews, subject to approval	1 to 3	C2
1.5	Order and prepare authorised laboratory cards	1 to 2	C2 with shared procurement
2.0	Acquisition pipeline, frozen before collection	2 to 3	C2
2.1	Family-specific read-only interaction sequence	2	C2
2.2	Canonical schema, logging and versioning	2 to 3	C2
2.3	Positioning jig and randomised session checklist	3	C2
2.4	Pilot study: timing resolution and repeatability; Flipper emulation coverage check	3	C2
2.5	Source corpus preparation: write clone-like cards, configure emulation	3	C2
3.0	Multi-session data collection	4 to 8	C2
3.1	Sessions 1 to 4, all classes interleaved, separate days	4 to 5	C2
3.2	Sessions 5 to 8	6 to 7	C2
3.3	Sessions 9 and 10, plus reserved unseen-source sessions	8	C2
3.4	Quality control and final split freeze	8	C2

WBS	Task	Weeks	Owner
4.0	Modelling and evaluation	9 to 13	C2
4.1	Fingerprint builder and baselines B1 to B7	9	C2
4.2	RF, SVM and KNN grouped training	9 to 10	C2
4.3	E1 to E3: ablation, session and source tests	10 to 11	C2
4.4	Calibration and open-set rejection layer	11	C2
4.5	E4 to E7, session-predictability diagnostic, cluster bootstrap intervals	11 to 12	C2
4.6	Dashboard and evidence export	12 to 13	C2
5.0	Integration and reporting	13 to 15	C2 with group
5.1	Unified output schema integration	13	Shared
5.2	Final figures, tables and results regeneration	13 to 14	C2
5.3	Thesis chapters, final review and viva preparation	14 to 15	C2

Table 12: Work breakdown structure.

Workload balance across the group holds because C2 owns provenance acquisition and modeling, while C1, C3, and C4 each retain an independent research question. Shared work is limited to hardware approval and scheduling, common naming and version conventions, and the unified result record.

The dominant constraint is that collection cannot be compressed. Ten independent sessions per source, on separate days with the setup rebuilt between them, need a minimum of five weeks of calendar time, no matter how many hours per day are available. That is what separates this component from the others in the group: C2 cannot recover a lost fortnight by working longer hours. Collection therefore starts in week 4 and ends in week 8. Everything upstream of it, meaning ethics clearance, card procurement, pipeline freeze, and corpus preparation, has to finish within weeks 1 to 3, and a delay in any of them consumes the buffer directly.

9. GANTT CHART

The schedule covers literature and evidence work, research design, pipeline construction, multi-session collection, modelling, open-set evaluation, prototype work, integration and report preparation across the 15-week semester.

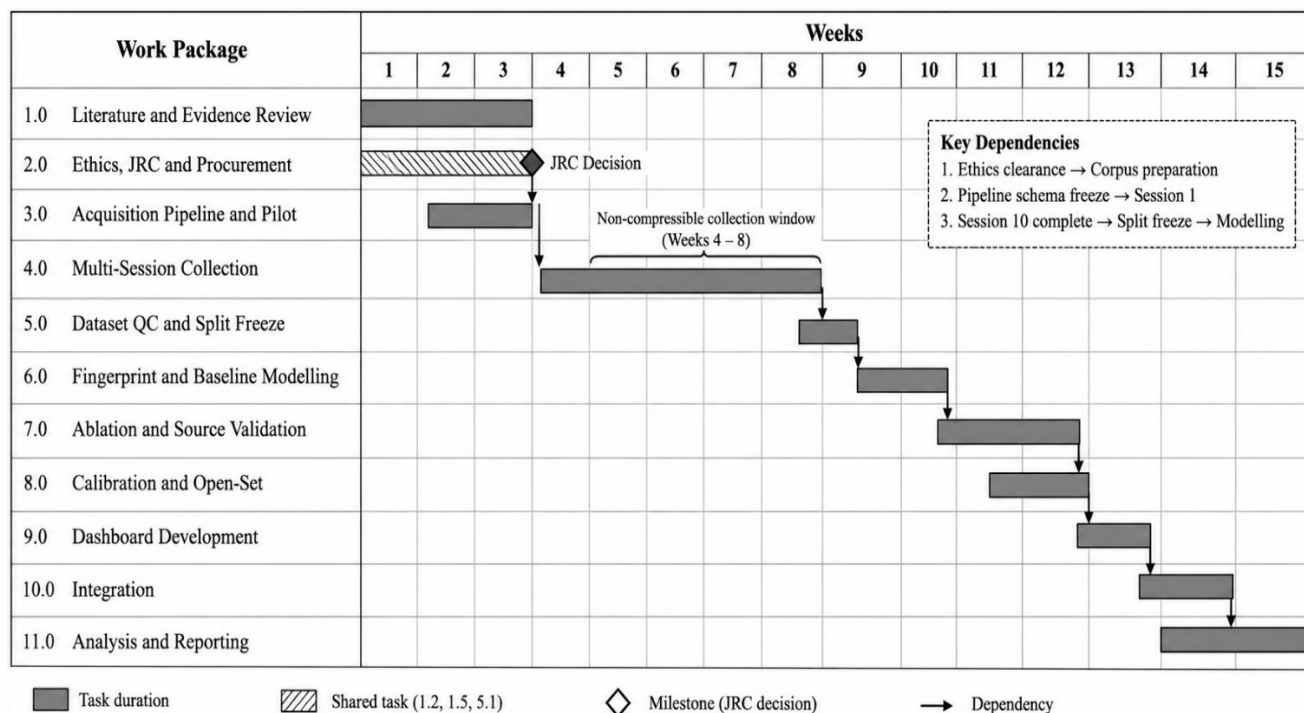


Figure 9: Gantt chart for the 15-week research period.

The critical path runs from approval and procurement together with the pipeline freeze in weeks 1 to 3, through independent collection in weeks 4 to 8, to the split freeze at week 8, then modelling and open-set evaluation in weeks 9 to 12, and integration and reporting in weeks 13 to 15. The collection window cannot be moved into a single late week without invalidating the multi-session design, which is the whole basis of the research question.

10. REFERENCES

- [1] B. Danev, D. Zanetti, and S. Capkun, “On physical-layer identification of wireless devices,” *ACM Computing Surveys*, vol. 45, no. 1, Art. no. 6, 2012, doi: 10.1145/2379776.2379782.
- [2] H. P. Romero, K. A. Remley, D. F. Williams, and C.-M. Wang, “Electromagnetic measurements for counterfeit detection of radio-frequency identification cards,” *IEEE Transactions on Microwave Theory and Techniques*, vol. 57, no. 5, pp. 1383–1387, 2009, doi: 10.1109/TMTT.2009.2017318.
- [3] D. Zanetti, B. Danev, and S. Capkun, “Physical-layer identification of UHF RFID tags,” in *Proc. 16th Annual International Conference on Mobile Computing and Networking (MobiCom)*, 2010, pp. 353–364, doi: 10.1145/1859995.1860035.
- [4] J. Li, A. Li, D. Han, Y. Zhang, T. Li, and Y. Zhang, “RCID: Fingerprinting passive RFID tags via wideband backscatter,” in *Proc. IEEE INFOCOM*, 2022, pp. 700–709, doi: 10.1109/INFOCOM48880.2022.9796663.
- [5] W. Lee, S. Y. Baek, and S. H. Kim, “Deep-learning-aided RF fingerprinting for NFC security,” *IEEE Communications Magazine*, vol. 59, no. 5, pp. 96–101, May 2021, doi: 10.1109/MCOM.001.2000912.
- [6] F. D. Garcia, G. de Koning Gans, R. Muijrrers, P. van Rossum, R. Verdult, R. Wichers Schreur, and B. Jacobs, “Dismantling MIFARE Classic,” in *Computer Security – ESORICS 2008*, Lecture Notes in Computer Science, vol. 5283. Berlin, Germany: Springer, 2008, pp. 97–114, doi: 10.1007/978-3-540-88313-5_7.
- [7] M. Lehtonen, D. Ostojic, A. Ilic, and F. Michahelles, “Securing RFID systems by detecting tag cloning,” in *Pervasive Computing*, Lecture Notes in Computer Science, vol. 5538. Berlin, Germany: Springer, 2009, pp. 291–308, doi: 10.1007/978-3-642-01516-8_20.
- [8] ISO/IEC 14443-3:2018, *Cards and Security Devices for Personal Identification—Contactless Proximity Objects—Part 3: Initialization and Anticollision*, 4th ed. Geneva, Switzerland: International Organization for Standardization, 2018.
- [9] ISO/IEC 14443-4:2018, *Cards and Security Devices for Personal Identification—Contactless Proximity Objects—Part 4: Transmission Protocol*, 4th ed. Geneva, Switzerland: International Organization for Standardization, 2018.

- [10] Y. Hmimou, M. Boutlane, M. Tabaa, A. Khiat, and Z. Hidila, “RFID-ExSim: A multi-scenario experimental dataset for collision timing, tag cloning, replay injection, and flooding stress in passive RFID systems,” *Data in Brief*, vol. 65, Art. no. 112575, 2026, doi: 10.1016/j.dib.2026.112575.
- [11] W. J. Scheirer, A. de Rezende Rocha, A. Sapkota, and T. E. Boult, “Toward open set recognition,” *IEEE Transactions on Pattern Analysis and Machine Intelligence*, vol. 35, no. 7, pp. 1757–1772, Jul. 2013, doi: 10.1109/TPAMI.2012.256.
- [12] L. Breiman, “Random forests,” *Machine Learning*, vol. 45, no. 1, pp. 5–32, 2001, doi: 10.1023/A:1010933404324.
- [13] C. Cortes and V. Vapnik, “Support-vector networks,” *Machine Learning*, vol. 20, pp. 273–297, 1995, doi: 10.1007/BF00994018.
- [14] T. M. Cover and P. E. Hart, “Nearest neighbor pattern classification,” *IEEE Transactions on Information Theory*, vol. 13, no. 1, pp. 21–27, Jan. 1967, doi: 10.1109/TIT.1967.1053964.
- [15] A. Niculescu-Mizil and R. Caruana, “Predicting good probabilities with supervised learning,” in *Proc. 22nd International Conference on Machine Learning (ICML)*, 2005, pp. 625–632, doi: 10.1145/1102351.1102430.

11. APPENDICES

The appendices below provide the supporting corpus records, acquisition controls, dataset rules, stakeholder evidence plan, ethics/JRC status, technical-figure requirements, proposal decision log and AI-use disclosure for Component C2.

Appendix A. Source Registry and Physical Corpus

Alias	Class	Family	Media type / role	Batch or purchase record
P01-P10	GENUINE	MIFARE Classic 1K	Project-owned original cards	Owned / Date 05.08.2026
C01-C06+	CLONE	Classic-compatible test media	At least 6 sources from at least 3 variants	Owned / Date 05.08.2026
P11-P20	GENUINE	NTAG215	Project-owned original tags	Owned / Date 05.08.2026
C07-C12+	CLONE	NTAG21x-compatible test media	At least 6 sources from at least 3 variants	Not yet
U01-U02	GENUINE	MIFARE Ultralight	Project-owned probe cards	Not yet
D1-01-D1-02	GENUINE	DESFire EV1	Project-owned probe cards	Not yet
D2-01-D2-02	GENUINE	DESFire EV2	Project-owned probe cards	Not yet
EMU01	EMULATOR	Flipper Zero	One physical device	Owned / Date 01.08.2026

Production batch, purchase date, supplier and media variant are maintained in the project source registry where available. Open-set probe sources are excluded from training and threshold selection.

Appendix B. Standard Acquisition and Session Checklist

The following checklist is used to maintain consistent data collection across C2 sessions.

1. Confirm required ethics, JRC and hardware permissions.
2. Use only project-owned or authorised laboratory NFC cards and tags.
3. Record the session ID, date, reader, firmware, host, script version and acquisition tier.
4. Rebuild the measurement setup and check the positioning jig.
5. Generate and record the randomised source order.
6. Interleave available source classes and card families during collection.
7. Run the approved non-destructive interaction sequence for each source.
8. Reposition the card or tag between trial blocks.

9. Record failed reads, retries and unsupported protocol conditions.
10. Store the raw session records without manually editing the measurements.
11. Run the required quality checks after each session.
12. Keep train, validation and test assignments unchanged during data acquisition.

Appendix C. Dataset Schema and Split Rules

C2 stores raw NFC observations, session information, source metadata, generated fingerprints, and dataset split information in separate structured files.

The dataset uses fields such as `observation_id`, `session_id`, `physical_source_id`, `source_class`, `card_family`, `acquisition_tier`, protocol-response fields, response timing, authentication information, and experiment metadata.

I use the physical source as the main grouping variable for model evaluation. I separate training, validation, and test data by source group to prevent leakage. I exclude open-set probe families from training and threshold selection.

Unsupported capabilities are represented as N/A rather than zero. I preserve raw data and generate processed datasets and fingerprints through the analysis scripts.

Appendix D. Ethics, JRC and Evidence Status

The C2 research uses only project-owned or explicitly authorized laboratory NFC cards, tags, and test devices.

The experiment does not use bank cards, transport cards, campus access credentials, employee credentials, or other third-party credentials. No third-party keys or real access-control secrets are collected.

The Proxmark3 and related specialist hardware are used in accordance with the applicable institutional and JRC approval process. Stakeholder discussions are conducted only after confirming the relevant consent and ethics requirements.

The project maintains approval letters, submission receipts, consent documentation, and anonymized stakeholder notes as supporting project evidence.

Appendix E. UI Sketch - C2 Provenance Dashboard

The C2 dashboard provides a simple interface for presenting the output of the provenance fingerprinting component.

The interface displays the Source ID, Session ID, card family, provenance verdict, calibrated confidence and evidence summary.

The possible verdicts are Original-like, Clone-like, Emulator-like or UNKNOWN.

The confidence value displayed in the UI sketch is an illustrative example only and does not represent a final experimental result.

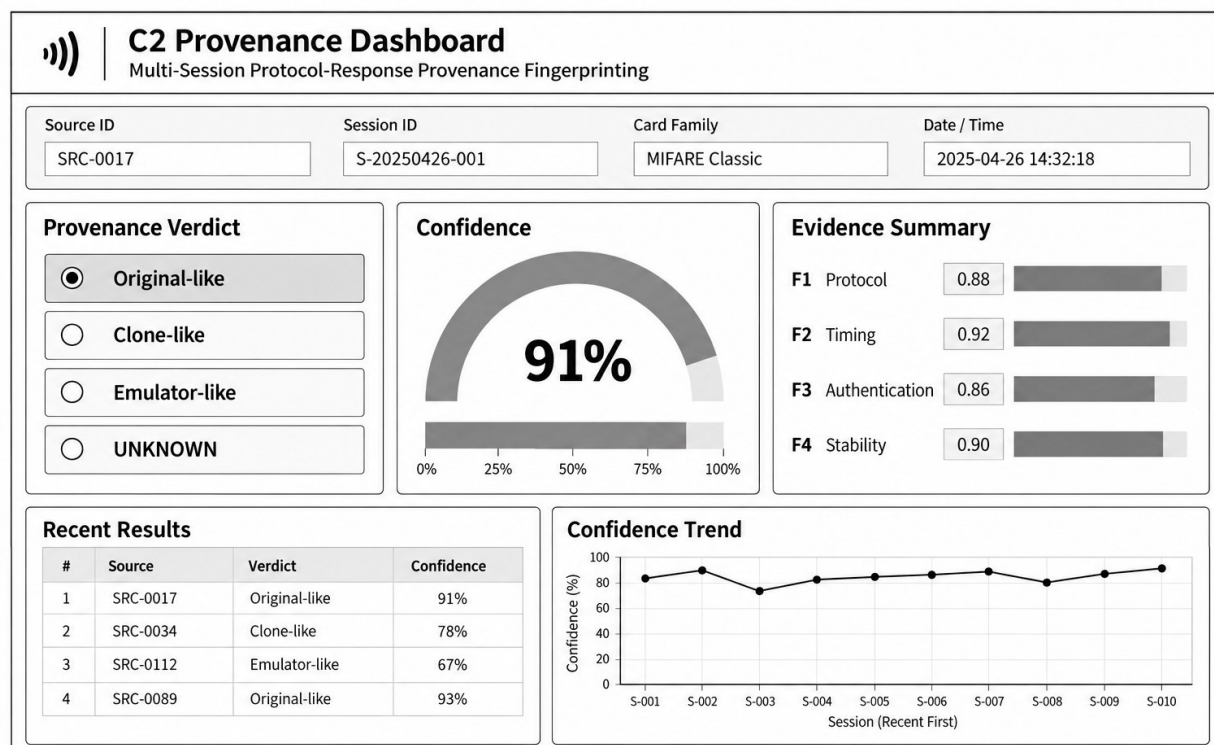


Figure 10: Simplified UI Sketch of the C2 Provenance Dashboard.

Appendix 2. Mandatory Proposal Evidence and Decision Log

Date	Claim / Problem	Evidence Collected	Alternatives Considered	Decision Made	Supervisor Discussion
2026-08-20	C2 needed a stronger contribution than a simple original-versus-clone classifier.	Component design review and comparison with the other framework components.	Single-session timing classifier; analogue RF fingerprinting; multi-session protocol-response provenance.	Adopt multi-session protocol-response provenance with held-out-source evaluation.	Meeting date : 2026-08-28
2026-08-25	External dataset selection.	RFID-ExSim reviewed: large event-level dataset but no C2 protocol-response provenance fields.	Main training source; external validation; context/gap evidence.	Use RFID-ExSim as context and gap evidence only.	Meeting date : 2026-08-28
2026-09-01	Closest NFC prior art required verification.	Lee, Baek and Kim reviewed: NFC reader plus SDR, repeated samples from the same 50 tags, closed-set task.	Describe as reader-only study; omit; retain with accurate critique.	Retain as NFC-specific prior art and limit the inference to same-population tag identification.	Meeting date : 2026-09-02
2026-09-01	Provenance could be confounded with card or chip family.	Corpus review showed family/test-media type could act as a predictive shortcut.	Pool families; include chip_type; within-family primary evaluation.	Use family-matched primary analysis; exclude chip_type and static identity from the primary model.	Meeting date : 2026-09-02
2026-09-10	Same physical source on both sides of a split would overstate generalisation.	Hierarchical repeated-measure structure and prior evaluation design were reviewed.	Random row split; session-only split; physical-source grouped split.	Use grouped evaluation by physical_source_id; keep the naive split only as diagnostic B6.	Meeting date : 2026-09-12
2026-09-10	UNKNOWN/open-set mechanism must not use final unseen sources for tuning.	Open-set principles and calibration literature reviewed.	Fixed probability threshold; one-class models; distance plus calibrated confidence.	Use development-only pseudo-unknown validation, calibrated confidence and distance checks; reserve final E4 sources.	Meeting date : 2026-09-12
2026-09-11	One Flipper Zero cannot establish emulator-device generalization.	Project inventory contains one physical emulator device.	Count configurations as devices; drop emulator; retain with limitation.	Keep emulator as a secondary class and report results with and without it; never count configurations as independent hardware.	Meeting date : 2026-09-12
2026-09-11	User and commercial evidence had not yet been collected.	No interview transcript, survey or verified local incident dataset was available.	Invent responses; omit requirements; keep claims provisional and schedule evidence collection.	Do not fabricate evidence; use provisional measurable requirements and a stakeholder interview protocol.	Meeting date : 2026-09-12

Appendix 3. AI Use Disclosure

AI Tool	Purpose of Use	What Was Generated/Assisted	How Output Was Verified	Final Student Contribution
ChatGPT (OpenAI, GPT-5.6 Sol)	Concept clarification and literature understanding	Explanations and summaries of NFC/RFID concepts, machine-learning methods, open-set recognition and selected research papers.	Compared with the original papers, standards, lecture/module material and project documents before use.	I selected the relevant evidence, interpreted it for C2 and take responsibility for the final research explanation.
ChatGPT (OpenAI, GPT-5.6 Sol)	Writing and language refinement	Suggestions for grammar, clarity, structure and wording of selected proposal sections.	Checked against the proposal template, research references and the final C2 methodology.	I reviewed, edited and selected the final wording and remain responsible for the submitted text.
ChatGPT (OpenAI, GPT-5.6 Sol)	Methodology and design review	Suggestions on dataset structure, evaluation design, requirements, risk items, WBS and consistency between sections.	Compared with the actual hardware, corpus plan, research objectives, validation strategy and supervisor	I made the final methodology, system-design and research decisions and will justify them during the viva.
ChatGPT (OpenAI, GPT-5.6 Sol)	Tables, appendices and checklist preparation	Draft table structures, appendix content, checklists and organisation of project information.	Verified against the proposal content, actual project records and module requirements before inclusion.	I completed, corrected and finalised the tables and appendices using the real project information.
ChatGPT (OpenAI, GPT-5.6 Sol)	Diagram and UI layout planning	Draft visual layouts, wireframes and figure ideas used only as planning/reference material.	Checked against the C2 architecture and proposal requirements. Final technical figures are manually recreated in draw.io	I create and retain the final editable technical figures and take responsibility for their accuracy and explanation.